

## memory.md — Project Memory

Keep this file updated. It's the single source of truth for "why did we decide this," so any teammate (or an AI coding assistant like Claude Code) can pick up the project cold. Every merged PR that changes a decision should add a line here.

### What this project is

SIM Swap & Transaction Fraud Risk Analytics — a hybrid rules+ML fraud-scoring prototype for banks. Full context: see `PRD.md`. Full architecture: see `ARCHITECTURE.md`.

### Fixed decisions (do not re-litigate without a team discussion)

- **Backend:** Python + Flask (not Django/Node) — matches report's REST API layer.
- **Database (Phase 1):** SQLite, accessed only through `backend/db/`. MySQL is a Phase 2 migration target, not Phase 1.
- **Auth:** JWT, issued at login, required on all `/api/risk/*` and `/api/dashboard/*` routes.
- **ML model:** Logistic Regression only for Phase 1 (interpretable, fast to retrain). No

neural nets / ensembles until Phase 2.

- **Decision labels:** exactly three — `ALLOW` , `STEP_UP` , `BLOCK` . Don't add a fourth without updating PRD.md §8 and every module that switches on this value.
- **No production telecom/bank data** — synthetic traffic only, ever, in Phase 1.

## Module ownership (see TEAM\_ROLES.md for full detail)

- `backend/api/` — Member A
- `backend/risk_engine/` — Member B
- `frontend/` — Member C
- `backend/db/` , `simulators/` , `notifications/` — Member D

## API contract snapshot

(Update this whenever an endpoint's request/response shape changes — this is the fastest way for teammates to avoid breaking each other.)

| Endpoint                             | Owner | Status  |
|--------------------------------------|-------|---------|
| <code>POST /api/auth/register</code> | A     | planned |
| <code>POST /api/auth/login</code>    | A     | planned |

| Endpoint                      | Owner                        | Status  |
|-------------------------------|------------------------------|---------|
| POST<br>/api/risk/evaluate    | A calls B's scoring function | planned |
| POST /api/otp/verify          | A                            | planned |
| GET<br>/api/dashboard/summary | A serves, C consumes         | planned |
| POST<br>/api/agents/heartbeat | D                            | planned |

## Open questions / parking lot

- Exact rule weights and score thresholds – to be tuned once synthetic data is flowing.
- Which geolocation source to use for "location mismatch" signal (see TECH\_STACK.md).
- Whether OTP delivery is simulated in logs only, or actually sent via a sandbox SMS API.

## Environment / secrets

Never commit real API keys. All keys and secrets live in

`.env` (git-ignored); `.env.example`

in the repo root lists every required variable with a placeholder. See TECH\_STACK.md §API

Keys for what each one is for and where to get a free/sandbox key.

Changelog

| Date                          | Change                                       | By |
|-------------------------------|----------------------------------------------|----|
| <i>fill in on<br/>kickoff</i> | Repo scaffolded from<br>PRD/architecture kit | —  |